

Informe de Remediación de Seguridad

Sistema de Gestión de Correspondencia — SISMAR

PREPARADO POR	DIRIGIDO A	FECHA	REFERENCIA
AISeNet — Equipo ASIA Arquitectura de Soluciones de IA	FOSCAL Equipo de Ciberseguridad	15 de julio de 2026	Auditoría SAST 14/07/2026 (20 hallazgos)

Resumen ejecutivo

El equipo ASIA de AISeNet recibió la auditoría de seguridad estática (SAST) practicada por FOSCAL sobre SISMAR, que identificó 20 hallazgos (4 críticos, 6 altos, 8 medios y 2 bajos). Verificamos cada punto contra el código fuente y ejecutamos un plan de remediación estructurado bajo la metodología STRATA v3 (test primero, verificación con evidencia y seguridad transversal). A la fecha de este informe, **19 de los 20 hallazgos están remediados y verificados**; el restante (SEC-016, gestor de paquetes) se propone como cambio controlado a coordinar con FOSCAL. El despliegue a pre-producción se mantuvo **bloqueado** durante toda la remediación.

19/20 REMEDIADOS	4/4 CRÍTICOS	6/6 ALTOS	37 TESTS EN VERDE	1 EN DISCUSIÓN
---------------------	-----------------	--------------	----------------------	-------------------

Estado por hallazgo

ID	SEV.	REMEDIACIÓN	ESTADO
SEC-001	CRÍTICA	.env fuera de control de versiones (rm --cached + .gitignore)	RESUELTO
SEC-002	CRÍTICA	Credenciales de prueba eliminadas del login + test de regresión	RESUELTO
SEC-003	CRÍTICA	Guard central de sesión/permisos en las 25 server actions	RESUELTO
SEC-004	CRÍTICA	GET /api/uploads exige JWT de sesión (401 sin sesión)	RESUELTO
SEC-005	ALTA	bcryptjs y cookie movidos a dependencies	RESUELTO
SEC-006	ALTA	Whitelist de tipo (PDF/PNG/JPG) y tamaño máx. 10 MB	RESUELTO
SEC-007	ALTA	Validación Zod (safeParse) integrada en las actions	RESUELTO
SEC-008	ALTA	Cookie httpOnly+secure+sameSite+path en set/refresh/clear	RESUELTO
SEC-009	ALTA	Rate limiting en login (5 intentos/min por usuario)	RESUELTO
SEC-010	ALTA	SVG bloqueado; tipos no whitelisted como attachment (anti-XSS)	RESUELTO
SEC-011	MEDIA	Content-Security-Policy añadido	RESUELTO
SEC-012	MEDIA	Strict-Transport-Security (HSTS) añadido	RESUELTO
SEC-013	MEDIA	Interfaz SessionPayload (elimina 'any' en auth)	RESUELTO
SEC-014	MEDIA	Bloques catch vacíos ahora registran con console.warn	RESUELTO
SEC-015	MEDIA	Logging limitado a error.message (sin stack traces)	RESUELTO
SEC-016	MEDIA	npm→pnpm: EN DISCUSIÓN (cambio controlado con el cliente)	EN DISCUSIÓN
SEC-017	MEDIA	Lógica de upload unificada en src/lib/uploads.ts (DRY)	RESUELTO

ID	SEV.	REMEDIACIÓN	ESTADO
SEC-018	MEDIA	createMany() elimina N+1 en recorridos y seed	RESUELTO
SEC-019	BAJA	Consecutivo con sufijo UUID (sin colisiones)	RESUELTO
SEC-020	BAJA	Contraseñas 8+ con complejidad (NIST)	RESUELTO

Verificación (Gate BDD)

- ✓ 37 pruebas automatizadas en verde (guards de autenticación, validación de archivos, esquemas Zod, atributos de cookie, rate limiting, cabeceras de seguridad y política de contraseñas).
- ✓ Compilación de producción sin errores (TypeScript estricto).
- ✓ Smoke E2E sobre el build de producción: inicio de sesión, registro de correspondencia con guards y validación activos, 401 en archivos sin sesión, cabeceras CSP/HSTS presentes y bloqueo del rate limiter al 6.º intento.
- ✓ Ningún despliegue a pre-producción durante la remediación.

Recomendación

AI SerNet considera SISMAR **apto para retomar el despliegue a pre-producción** una vez ejecutado el paso operativo de **rotación de las contraseñas de los usuarios iniciales** (que la auditoría señaló) y acordado el tratamiento de SEC-016. Quedamos atentos a la revisión del cliente para el cierre formal.